

ContractSentinel — Project Report

Last updated: 2026-08-01 · `main` @ `1fae197d`

1. What it is

ContractSentinel is a local-first **AI contract-risk analyzer**. A user uploads a PDF/DOCX contract; a fixed **7-node LangGraph pipeline** (running Qwen3 via local Ollama) splits it into clauses, retrieves supporting legal evidence, validates which clauses are genuinely risky, scores each Low/Medium/High, drafts a safer rewrite, and compiles a branded PDF report that is delivered to the user's Google Drive + emailed via Gmail. It behaves like a real multi-tenant SaaS (landing page, auth, per-user data isolation, per-user Drive) while running entirely on a local box.

2. Fixed architecture (constitution §2 — immutable)

7 sequential nodes + exactly 2 conditional edges:

- IngestAgent** — parse PDF/DOCX (OCR fallback); now ****decrypts the at-rest-encrypted contract to a temp file**** before parsing (feature 036).
- ClauseSplitterAgent** — regex pre-pass + LLM boundary/type refinement (Lever-F index mode).
- CRAG retrieval** — per clause, BGE-M3 embedding + FAISS local KB; confidence < 0.73 → live web fallback (conditional edge #1).
- Self-RAG validation** — relevance / ISREL / ISSUP judgments; discard vs validate; recall floor (027).
- RiskScoreAgent** — Low/Medium/High + rationale.
- route_on_risk** (conditional edge #2) → **RedlineAgent** (safer rewrite) or **SkipRedline**.
- ReportAgent** — compiles the report + evidence trail.

Post-terminal (NOT a graph node): **MCP delivery** → Google Drive + Gmail.

Models: generative **Qwen3:8b** (Ollama), embeddings **BGE-M3** (Ollama) — kept strictly separate (§8).

3. Feature history (all merged to main)

#	Feature	Status
001–009	State schema + the 7 nodes	shipped
010–012	MCP Drive/Gmail delivery, runner + FastAPI + SSE, SQLite persistence	shipped
013–024	Full Next.js frontend (design system, upload, processing, report, dashboard, contracts, settings, integrations)	shipped
014/019	Single-user auth → per-user data isolation (multi-tenant)	shipped
020–022	Profile + report-to-owner-email, report history, Analysis Workspace	shipped
025/028/029	Pipeline latency levers + determinism/variance harness	shipped
026/027	Offline evaluation harness + Self-RAG recall floor	shipped

030	Professional PDF report + branded HTML email	shipped
031	Per-user Google Drive (per-user OAuth)	shipped
032	Security Tier 1 — OAuth-token encryption at rest, session hardening, rate-limit + lockout	shipped
033	Drive "ContractSentinel" folder + human-readable report names	shipped
034	Forgot-password (emailed time-limited reset link)	shipped
035	Security Tier 2 — prompt-injection defense	shipped
036	Contract encryption at rest	shipped

4. Security posture

- **Auth:** email+password (bcrypt+SHA-256 pre-hash), HS256 JWT in an httpOnly cookie; sliding 30-min idle + 8-h absolute cap; `session_epoch` server-side invalidation (logout-everywhere, password-change, reset); per-IP rate-limit + persisted per-account lockout; forgot-password with hashed single-use time-limited tokens and no email-existence disclosure.

- **Encryption at rest (Fernet):** per-user + central **OAuth tokens** (032) and **uploaded contract files** (036), one key seam (`app/security/crypto.py`).

- **Prompt-injection defense (035):** untrusted contract/evidence text is fenced in per-call-nonce delimiters inside a `user` message, trusted instructions in a `system` message, with deterministic breakout neutralization — across all 4 generative LLM calls.

- **Per-user isolation:** every data read is scoped to the owning account; per-user Drive.

- **Security headers (037):** every API response carries `X-Content-Type-Options`, `X-Frame-Options: DENY`, a strict CSP, `Referrer-Policy`, COOP, Permissions-Policy (HSTS available, TLS-gated).

- **Upload hardening (037):** magic-byte validation rejects a file whose content doesn't match its extension (`PDF→%PDF`, `DOCX→ZIP`), not just the extension.

Known follow-ups (deferred): TLS termination (ops), publish the Google OAuth app to Production (fixes `invalid_grant` token expiry), encryption at rest for `*generated reports/parsed text*`, **dependency scanning (pip-audit/npm audit in CI)**, honest-LLM-failure surfacing.

5. Tech stack

- **Backend:** Python, FastAPI, LangGraph, SQLite (+ Alembic, head **0008**), Ollama (Qwen3:8b + BGE-M3), FAISS, reportlab, cryptography (Fernet), MCP SDK. **902 tests**.

- **Frontend:** Next.js 14 + TypeScript + Tailwind + Recharts. **237+ tests**.

6. Running the app locally

Prerequisites

- **Ollama** running with the models pulled:

```
ollama pull qwen3:8b
ollama pull bge-m3
```

(6 GB GPU: Qwen3:8b runs ~70/30 GPU/CPU; pre-warm before a run.)

- Python venv in `backend/.venv` (deps installed); Node deps installed in `frontend/`.
- Google OAuth for delivery (optional): `data/secrets/google_credentials.json` +

`scripts/oauth_bootstrap.py` (see the OAuth notes).

Backend (port 8000) — from `backend/`

```
# 1. one-time / after pulling: apply DB migrations (creates jobs/users/password_reset_tokens)
.venv/Scripts/python.exe -m alembic upgrade head
```

```
# 2. start the API (local HTTP dev → AUTH_COOKIE_SECURE=False; the default True needs TLS)
AUTH_COOKIE_SECURE=False .venv/Scripts/python.exe -m uvicorn app.api.main:app --host 127.0.0.1 --port 8000
```

(PowerShell: ``$env:AUTH_COOKIE_SECURE="False"; .venv\Scripts\python.exe -m uvicorn app.api.main:app --host 127.0.0.1 --port 8000``)

Frontend (port 3000) — from `frontend/`

```
npm run dev
```

`frontend/.env.local` must contain `NEXT_PUBLIC_API_PROVIDER=real` (proxies to :8000).

Open <http://localhost:3000>.

Run the tests

```
# backend (from backend/)
.venv/Scripts/python.exe -X utf8 -m pytest -q
# frontend (from frontend/)
npm run test
```

7. Reversible feature flags (`config.py`)

`PROMPT_INJECTION_DEFENSE_ENABLED`, `CONTRACT_ENCRYPTION_AT_REST_ENABLED`,
`MCP_DRIVE_HUMAN_READABLE_NAMES`, `MCP_REPORT_PDF_ENABLED`, `PER_USER_DRIVE_ENABLED`,
`AUTH_COOKIE_SECURE`, and the latency levers — each restores prior behavior when flipped.

8. Development workflow (constitution)

Strict **spec** → **plan** → **tasks** → **implementation**, every artifact gated by the
`spec-reviewer` subagent (VERDICT: APPROVED required to advance), TDD (tests fail first),
one branch per feature, ff-merge to `main`. Encryption-at-rest scope is governed by
explicit constitution amendments (032 tokens, 036 contracts).